CONFIDENTIAL — INTERNAL

VERSION 1.0 · MARCH 2026

Security, Encryption & *Compliance* Notes

A complete reference covering data encryption decisions, regulatory compliance, certification roadmap, and module-by-module implementation checkpoints for the Healthcare Platform. This document applies to the entire product — every module, every phase, every market.

Backend developers | Frontend developers | QA engineers | Stakeholders & investors | Product & architecture

---

SECTION 01

Why this matters — for the whole product

Healthcare data is the most sensitive category of personal data in every legal system in the world. A single breach — one unencrypted database, one exposed API, one stolen backup — can result in fines in the crores, loss of hospital contracts, and permanent reputational damage. This is not a "we'll add it later" problem.

This document covers the complete product — all modules, all phases, all markets.

Encryption is a database and infrastructure decision made once, at the start. If you wait until Module 3 to encrypt lab results, you will have unencrypted patient data sitting in production that must be migrated. That is painful, expensive, and legally risky.

We are a Business Associate — not just a technology vendor.

Because our platform stores and processes protected health information on behalf of hospitals, we are legally classified as a "Business Associate" (HIPAA) or "Data Processor" (GDPR/DPDP). We are directly liable — not just the hospital. The hospital cannot absorb our legal exposure.

Encryption built from day one costs almost nothing extra.

> Adding AES-256 column encryption to a new table takes 30 minutes. Retrofitting it onto a production table with 500,000 patient records takes weeks of migration, downtime planning, and rollback testing. Build it right from the start.

SECTION 02

Three layers of encryption — all required

All three layers must be active. Each one protects against a different type of attack. Missing any one layer means the other two can be bypassed.

LAYER	WHAT IT COVERS	HOW	WHEN
1. In transit	All data moving between client → API, API → DB, API → Redis, service → service	TLS 1.3 minimum. No plain HTTP anywhere, including internal services.	`Before first deploy`
2. Column level (at rest)	Sensitive fields in the database — PII, clinical data, credentials	AES-256-GCM in application layer before writing to DB. DB stores ciphertext only.	`Before first deploy`
3. Volume level (at rest)	Entire DB volume, backup files, log exports, object storage	AWS RDS / GCP Cloud SQL managed encryption. Must be enabled at DB creation.	`Before first deploy`

> **Most common mistake:**
> Teams enable column encryption but leave volume encryption off. If someone steals a DB backup file, all column encryption is bypassed because they have the raw volume. Both layers are required — they protect against different threats.

> **The golden rule:**
> If combining any two plain-text fields can identify a specific patient — treat the combination as PII and encrypt both. Example: date_of_birth alone is not PII. hospital_name alone is not PII. But date_of_birth + hospital_name + department together can uniquely identify a patient. Encrypt all of them.

SECTION 03

Field-level encryption map — all modules

Every sensitive database field, the encryption method, and which module it first appears in. Developers must implement encryption before the module goes live — not after.

Critical — AES-256-GCM · encrypt + restrict + access log

> These fields are "special category" data under GDPR, DPDP, and HIPAA. Every access must be logged. Accessing them requires elevated permissions.

FIELD	TABLE	METHOD	EXTRA RULE	MODULE
full_name	patients	AES-256-GCM	Mask in UI for non-clinical roles	Module 2
date_of_birth	patients	AES-256-GCM	Store age separately for analytics — never expose DOB	Module 2
national_id / aadhaar	patients	AES-256-GCM	Show last 4 digits only in UI	Module 2
diagnosis	medical_records	AES-256-GCM	Doctor + SA only. Every view logged.	Module 3
medical_history	patients	AES-256-GCM	Doctor + SA only	Module 3
mental_health_notes	medical_records	AES-256-GCM	Separate permission. Every access logged with reason.	Module 3
hiv_status	sensitive_records	AES-256-GCM	Separate table. Strictest access control.	Module 3
genetic_data	sensitive_records	AES-256-GCM	Separate table. Explicit written consent required.	Module 3

FIELD	TABLE	METHOD	EXTRA RULE	MODULE
lab_results	lab_reports	AES-256-GCM	Doctor + lab tech (own orders) only	Module 4
prescription_details	prescriptions	AES-256-GCM	Doctor + pharmacist access	Module 4

High — AES-256-GCM · encrypt + mask in UI

FIELD	TABLE	METHOD	UI MASKING RULE	MODULE
phone_number	patients / users	AES-256-GCM	Show +91 ****6789	Module 2
email	patients / users	AES-256-GCM + hash index	Show j***@g**.com	Module 1
home_address	patients	AES-256-GCM	Show city only to non-clinical roles	Module 2
insurance_id	patients	AES-256-GCM	Show last 4 digits only	Module 2
passport / id_number	patients	AES-256-GCM	Show ****1234	Module 2
blood_group	patients	AES-256-GCM	Doctor access only	Module 2
allergies	patients	AES-256-GCM	Doctor + emergency access	Module 2
emergency_contact	patients	AES-256-GCM	Mask phone number in UI	Module 2

Medium — hashed or tokenised · never stored plain text

FIELD	TABLE	METHOD	RULE	MODULE
password	users	argon2id	Never stored plain. Never logged. Never returned in API response.	Module 1

FIELD	TABLE	METHOD	RULE	MODULE
invite_token	invites	SHA-256 hash	Raw token sent in email only. Only hash stored in DB.	Module 1
reset_token	invites	SHA-256 hash	Expires in 1 hour. One-time use only.	Module 1
2fa_secret	users	AES-256-GCM	Required if 2FA feature is added	Future
api_keys	api_keys	SHA-256 hash	Show raw key once on creation. Store only hash.	Future
payment / card data	billing	Do not store	Use Razorpay / Stripe tokenisation. Never store raw card numbers.	Module 5

Low — TLS in transit only · no column encryption needed

FIELD	REASON IT IS LOW RISK	NOTE
appointment_date	Not PII in isolation	Never expose combined with patient name to non-clinical roles
hospital_name	Public information	—
department	Operational metadata	—
invoice_amount	No PII	Reports must be aggregated — never per-patient breakdown to non-clinical roles
working_hours	Public config data	—
audit_logs	System metadata	Append-only. Strip PII from log entries before writing.

SECTION 04

Infrastructure encryption requirements

These are platform-level decisions that affect all modules equally. Most must be set up before the first production deploy.

LAYER	WHAT TO DO	WHY IT MATTERS	WHEN
DB volume encryption	Enable on AWS RDS / GCP Cloud SQL at creation. Cannot be added after without migration.	Stolen storage volume = unreadable data	Before first deploy
Backup encryption	Enable encrypted automated backups. Never export an unencrypted dump.	Most breaches involve stolen backup files, not live DBs	Before first deploy
TLS — client to API	HTTPS only. Enforce HSTS. TLS 1.2 minimum, prefer TLS 1.3.	All data in transit unreadable to interception	Before first deploy
TLS — internal services	API → DB, API → Redis, microservice → microservice. All must use TLS.	Internal plain HTTP is a common overlooked breach vector	Before first deploy
Log sanitisation	Never log PII. Strip email, name, national ID, diagnosis before writing any log.	Logs go to third-party tools. PII in logs = breach.	Before first deploy
Key Management (KMS)	Move ENCRYPTION_KEY from .env to AWS KMS / GCP KMS / HashiCorp Vault.	Env vars leak in logs, rotate poorly, aren't audited	Phase 2
Object storage (S3/GCS)	Enable server-side encryption on all buckets. Block all public access.	Lab reports, documents stored here are patient data	Before Module 4
Data residency routing	India → AWS ap-south-1 Mumbai. UAE → me-south-1 Bahrain. EU → eu-west.	DPDP, UAE PDPL, GDPR all have data localisation laws	Before expansion

SECTION 05

Legal & regulatory requirements by region

Every country you operate in has its own health data laws. These apply from the moment the first patient record is stored in that region — not from when you formally register there.

🇮🇳 India — current market · applies now

> **DPDP Act 2023 is in force today.**
> Health data is "sensitive personal data" — the highest protection tier. You must document what you collect, why, how consent is taken, and how you delete it on request. This is not optional — it applies from your first patient record.

LAW	WHAT IT REQUIRES FROM US	PENALTY
DPDP Act 2023	Explicit consent before collecting health data. Purpose limitation — only use data for stated purpose. Right to erasure within reasonable time. Breach notification to Data Protection Board of India. Appoint DPO at enterprise scale.	Up to ₹250 crore per breach
IT Act 2000 — Section 43A	Reasonable security practices for sensitive personal data. ISO 27001-aligned practices. Mandatory breach notification to affected parties.	Civil liability — compensate affected individuals
ABDM / NHA guidelines	If connecting to government health stack or enabling ABHA ID linkage, NHA certification is mandatory. Interoperability standards must be followed.	Access to govt health network revoked

Data residency: Store India patient data in AWS ap-south-1 (Mumbai) or ap-south-2 (Hyderabad). Do not use overseas-only regions for India patient data.

🇦🇪 UAE / GCC — expansion market

LAW	WHAT IT REQUIRES	NOTE
UAE PDPL 2021	Health data = special category. Explicit consent. Data must stay in UAE or approved countries. Breach notification required.	AWS me-south-1 Bahrain or UAE region required
HAAD / DOH	Health Authority Abu Dhabi and Dubai Health Authority both require platform compliance before operating in their emirate. Separate registration per emirate.	Market entry gate — must apply before launching
Saudi PDPL	Similar to UAE. Data localisation in Saudi cloud region required for KSA operations.	AWS me-central-1 required for KSA

🇪🇺 Europe — future expansion

LAW	WHAT IT REQUIRES	PENALTY
GDPR Article 9	Health data = special category. Explicit consent. Right to erasure, portability, and access. Breach notification within 72 hours. DPA registration in each EU country.	Up to 4% of global annual revenue
EHDS	European Health Data Space. Requires support for secondary use of health data with patient consent. Phasing in 2025-2027. Design architecture to support it now.	Plan now · Enforce 2027

Data residency: EU patient data cannot leave EU/EEA without Standard Contractual Clauses. Use AWS eu-west or eu-central regions.

🇺🇸 USA — future expansion

> **BAA requirement:**
> Before storing any US patient data, every vendor in our stack must sign a Business Associate Agreement. AWS offers HIPAA BAAs. SendGrid / Mailgun / SES do too. If a vendor does not offer a BAA, we cannot use them for PHI data.

LAW	WHAT IT REQUIRES	PENALTY
HIPAA	All PHI must be encrypted, access-controlled, and audited. BAA required with every vendor that touches PHI. We as a SaaS are directly liable.	Up to $1.9M per year per violation category
HITECH Act	Extends HIPAA. Mandatory breach notification. Increases penalties significantly for wilful neglect.	Covered under HIPAA penalties

SECTION 06

Certification roadmap

These certifications determine whether enterprise hospital clients sign contracts with us, whether we can enter new markets, and whether investors and acquirers take us seriously. Plan the timeline now.

Required immediately

DPDP Act 2023 compliance

Not a certificate but a legal obligation in force today. Document: data collected, consent mechanism, retention policy, deletion process. Appoint a Data Protection Officer contact person.

Required today ₹250 crore penalty

Internal security policy

Written security policy covering: password rules, access control, incident response procedure, vendor selection criteria, acceptable use. Required for any enterprise client due diligence audit.

Required today Blocks enterprise deals

Start within 6 months of launch

ISO 27001

Information Security Management System. Not legally required in India but every hospital chain and enterprise client will demand it before signing. Start early — 6-12 months to certify. Budget ₹8-15 lakh for consultant and audit.

6-12 months Blocks enterprise sales

ABDM / NHA certification

Required if any hospital client is govt-affiliated or wants ABHA ID linkage. Register with National Health Authority early — process takes 3-6 months.

3-6 months Blocks govt hospital clients

Annual penetration testing

External security firm tests API, auth flows, and infrastructure before each major release and annually thereafter. Required for ISO 27001 and SOC 2 compliance. Budget ₹2-5 lakh per test.

Before go-live ₹2-5L per test

Before international expansion

SOC 2 Type II

No US hospital will sign without it. Covers security, availability, confidentiality. 12+ month process. Start 1 year before planned US entry. Use Vanta or Drata to automate evidence collection.

12+ months Required for US market

HIPAA compliance program

Formal program including BAA templates, PHI handling procedures, breach response plan, and annual staff training. Required before any US patient data is stored.

Before US entry $1.9M/year penalty

GDPR compliance program

HAAD / DOH registration

EU representative appointment, DPA registration per country, Privacy by Design codebase review, DPO appointment, cookie consent. 3-6 months + legal fees.

Before EU entry 4% global revenue

Market entry requirement for UAE. Apply to Health Authority Abu Dhabi or Dubai Health Authority before operating. Separate registration per emirate.

Before UAE entry Market entry gate

SECTION 07

Module-by-module compliance checkpoints

Each module that introduces new types of data has specific encryption and compliance requirements that must be completed before that module goes to production.

MODULE 1

Auth + Admin

Current

Encryption before go-live:

→ AES-256-GCM on users.email + SHA-256 email_hash for lookup index

→ argon2id on password_hash — never bcrypt for new systems

→ SHA-256 on invite tokens and reset tokens — only hash stored in DB

→ TLS 1.3 on all endpoints including Redis connection

→ DB volume encryption enabled at setup — cannot be added after creation

→ Backup encryption enabled — never export unencrypted dump

→ Log sanitisation — strip email from all application logs before writing

→ JWT stored in httpOnly + Secure + SameSite=Strict cookie only

Compliance before go-live:

→ DPDP compliance documentation started — data register created

→ Internal security policy written

→ audit_logs table is append-only — UPDATE/DELETE revoked from app DB user

MODULE 2

Patients + Appointments

Next

⚠ First real patient PII enters the system. DPDP applies from this module.

→ AES-256-GCM on: full_name, date_of_birth, national_id, phone, email, home_address, insurance_id, blood_group, allergies, emergency_contact

→ Patient consent mechanism must be live before record creation is possible

→ Right to erasure pipeline must be built and tested

→ UI masking for all high-sensitivity fields per role (phone, email, Aadhaar)

→ GET /patients/:id/basic endpoint returns only safe fields for receptionist / lab / pharmacy

MODULE 3

Doctors + Records

Phase 2

⚠ Most sensitive clinical data enters here. Highest encryption tier applies.

→ AES-256-GCM on: diagnosis, medical_history, mental_health_notes

→ hiv_status and genetic_data in separate table with separate access policy

→ Every access to mental_health_notes logged with user_id + timestamp + reason

→ Doctor access strictly scoped to own assigned patients at query level

→ Begin ISO 27001 process — certifiers audit clinical data handling

MODULE 4

Lab results, prescriptions, and file uploads introduced.

Lab + Pharmacy Phase 3	→ AES-256-GCM on: lab_results, prescription_details → S3/GCS bucket for lab report files — server-side encryption on, no public access → ABDM integration if required — NHA certification must be in progress by now → KMS should replace .env ENCRYPTION_KEY by this module
MODULE 5 **Billing + Reports** Phase 4	**Financial data introduced. PCI-DSS relevance if card payments processed.** → Never store raw card data — Razorpay / Stripe tokenisation only → Analytics and reports — aggregated data only for non-clinical roles, never per-patient PII → ISO 27001 should be complete or in final audit stage → Annual penetration testing must be in schedule

SECTION 08

Action checklist

Tick these off as completed. This covers the full product lifecycle from Phase 1 through international expansion.

Before Phase 1 goes to production

- [ ] **Database volume encryption enabled** — Dev / Infra
  AWS RDS / GCP Cloud SQL — must be set at creation. Cannot be added after without migration.
- [ ] **TLS 1.3 on all endpoints including internal services** — Dev
  Client → API, API → DB, API → Redis. All encrypted.
- [ ] **Email encrypted (AES-256) · password argon2id · tokens SHA-256** — Dev
  Per field-level encryption map in Section 03
- [ ] **Backup encryption enabled** — Dev / Infra
  Automated encrypted backups configured on DB. Never export unencrypted dump.
- [ ] **Log sanitisation implemented** — Dev
  Strip email, name, national ID from all application logs before writing.
- [ ] **audit_logs table is append-only** — Dev
  Revoke UPDATE and DELETE privileges from app DB user on this table.
- [ ] **JWT in httpOnly + Secure + SameSite=Strict cookie** — Dev
  Never stored in localStorage. Cookie flags enforced.
- [ ] **DPDP compliance documentation started** — PM / Legal

Data register written: what we collect, why, how long, how to delete on request.

- [ ] **Internal security policy written** — PM
  Password rules, access control, incident response, vendor selection criteria.

Before Module 2 (patients) goes to production

- [ ] **All patient PII fields encrypted per Section 03 map** — Dev
  full_name, DOB, national_id, phone, address, insurance_id, blood_group, allergies, emergency_contact
- [ ] **Patient consent mechanism live** — Dev / PM
  Explicit consent captured before patient record creation. Stored with timestamp.
- [ ] **Right to erasure pipeline built and tested** — Dev
  Patient deletion anonymises PII across all tables. Tested end-to-end.
- [ ] **UI masking implemented for all sensitive fields** — Frontend Dev
  Phone → ***6789, email → j***@g**.com, Aadhaar → XXXX-XXXX-1234

Within 6 months of launch

- [ ] **ISO 27001 process started** — Leadership
  Engage consultant. Gap analysis done. 6-12 months to certification.
- [ ] **KMS implemented — encryption key moved from .env** — Dev / Infra
  AWS KMS / GCP KMS / Vault. Auto-rotation enabled. Audited access.
- [ ] **First penetration test completed** — PM / Infra
  External security firm. API, auth flows, infrastructure tested.
- [ ] **DPO (Data Protection Officer) appointed** — Leadership
  Can be internal or external. Required under DPDP before enterprise scale.

Before international expansion

- [ ] **Multi-region data residency routing built** — Dev / Infra
  India → Mumbai. UAE → Bahrain. EU → eu-west. Routing logic live before first foreign patient record.
- [ ] **SOC 2 Type II started (for US expansion)** — Leadership
  Start 12 months before US entry. Use Vanta or Drata to automate evidence collection.

- [ ] **HIPAA BAAs signed with all vendors (for US)** — Legal
  AWS, email provider, monitoring tools — all must have signed BAA before US PHI is stored.
- [ ] **GDPR compliance program complete (for EU)** — Legal
  EU representative, DPA registration, cookie consent, Privacy by Design review of codebase.
- [ ] **HAAD / DOH registration complete (for UAE)** — Legal / BD
  Applied and approved before operating in UAE. Each emirate requires separate registration.